

# Детекција, инцидент и рањивости

Детекција догађаја, поступање у инциденту и управљање  
рањивостима



# Садржај презентације

01

## Детекција

Сигнал, временски прозор и тест прага.

05–11

02

## Triage и реакција

Контекст, власник и временска линија.

12–17

03

## Рањивости

Изложеност, приоритет и доказ корекције.

18–21

04

## Учење

Постинцидентни преглед и примена.

22–30

## Увод

Догађај, значај и основни појмови (03–04).

## УВОД

# Од безбедносног сигнала до инцидента

Систем ставља сигнал у контекст, процењује утицај и тек затим одређује потребан ниво реакције.

## ПРЕДМЕТ АНАЛИЗЕ

### Ризик који се анализира

Безбедносни догађај није аутоматски инцидент. Систем најпре препознаје сигнал, затим га ставља у контекст и тек онда одређује да ли је потребна реакција. Такав ток спречава и игнорисање проблема и непотребно алармирање због сваког одступања.

## ЗНАЧАЈ

### Значај за безбедност система

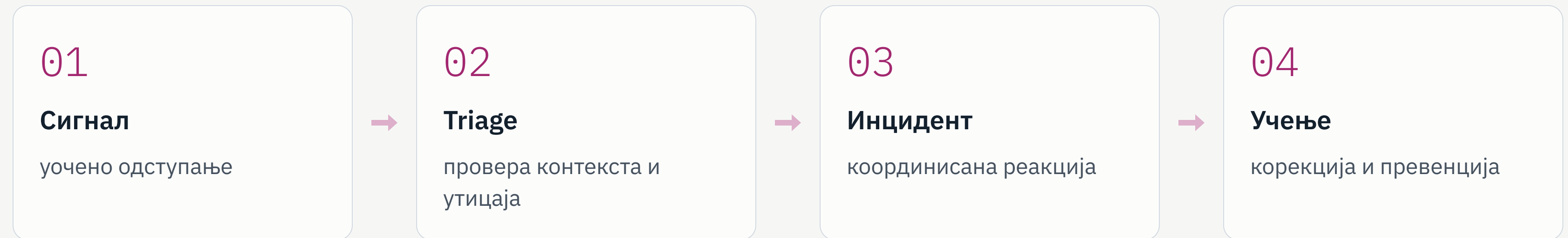
Управљање инцидентом даје структуру тренутку када је најлакше изгубити контекст. Рањивост постаје решив проблем када је повезана са имовином, приоритетом, власником и доказом да је корекција проверена.

#### КРИТЕРИЈУМ ПРОВЕРЕ • Проверљив резултат

Одлука је јасна, примењује се на серверу и оставља поновљив доказ успешног и одбијеног исхода.

# Основни појмови

Сигнал, triage, инцидент и учење представљају различите фазе поступања у безбедносном догађају.



## ЗАКЉУЧАК

Значајни сигнали пролазе процену контекста и утицаја пре отварања инцидента. Исход анализе остаје доступан за наредне одлуке.

# 01

ПРВИ ДЕО

## Детекција

Детектор препознаје образац, а сигнал задржава контекст потребан за процену.

Праг

Временски прозор

Доказ теста

# Сигнал

уочено одступање

**01** Сигнал настаје када догађаји пређу праг унутар одређеног временског прозора.

Питање: који улаз покреће ову одлуку?

**02** У приказаном правилу један неуспео покушај није сигнал, а успешне пријаве се не броје.

Питање: која граница мора бити видљива?

**03** Сигнал носи контекст: назив правила, субјекта, изворну адресу и број покушаја.

Питање: који доказ остаје после исхода?

## ПИТАЊЕ ЗА АНАЛИЗУ

Који праг и који временски прозор раздвајају уобичајену грешку од сигнала у вашем систему?

# Сигнал, alert и инцидент

Поређење приказује функцију сваког елемента и ограничење његове самосталне примене.

| Стање           | Шта представља                                | Потребна реакција                      |
|-----------------|-----------------------------------------------|----------------------------------------|
| Сигнал          | Сиров догађај или одступање.                  | Сачувати контекст и проверити правило. |
| Alert           | Сигнал који је прешао дефинисан праг.         | Triage и процена приоритета.           |
| Инцидент        | Потврђен или вероватан безбедносни утицај.    | Координисана реакција и следљив ток.   |
| Налаз рањивости | Потенцијална изложеност коју треба проценити. | Власник, рок и доказ корекције.        |

# Праг у временском прозору

Илустративно правило за исти субјект и изворну адресу.



## Тумачење

Прозор и праг су параметри овог примера. Сигнал је улаз за triage, а не доказ напада.

# Правило детекције додаје контекст сигналу

C# • илустративни пример

```
1 public IReadOnlyList<SecuritySignal> Detect(  
2     IReadOnlyCollection<LoginAttempt> attempts,  
3     DateTimeOffset now)  
4 {  
5     return attempts  
6         .Where(attempt => !attempt.Succeeded  
7             && IsInsideWindow(attempt, now))  
8         .GroupBy(attempt =>  
9             (attempt.SubjectId, attempt.SourceIp))  
10        .Where(group => group.Count() >= _threshold)  
11        .Select(group => new SecuritySignal(  
12            Name, group.Key.SubjectId,  
13            group.Key.SourceIp, group.Count()))  
14        .ToArray();  
15 }
```

## ТУМАЧЕЊЕ

Праг и временски прозор спречавају да свака неуспела пријава постане сигнал.

## БЕЗБЕДНОСНА ГРАНИЦА

Сигнал носи субјекта, адресу и број покушаја, па се може проверити и објаснити.

# Испод прага нема сигнала

C# • илустративни пример

```
1 [Test]
2 public void
3     Detect_WhenFailuresAreBelowThreshold_RaisesNothing()
4 {
5     var signals = _rule.Detect(
6         Attempts.Failures(
7             "ana", "203.0.113.10", 2, Now), Now);
8     Assert.That(signals, Is.Empty);
9 }
```

## ДОКАЗ

Негативан сценарио проверава да правило не подиже узбуну пре прага.

## ОЧЕКИВАНИ ИСХОД

Тест мења само број покушаја и очекује празну листу сигнала.

# Сигнал тражи контекст

Наведена правила остају видљива у имплементацији, тестовима и ревизији.

- 
- 01** Праг детекције треба да има смисао и разлог, не само произвољну бројку.  
Јасно правило
  - 02** Затварање упозорења чува образложење, јер је то знање за следећи сличан случај.  
Проверљива примена
  - 03** Рањивост се сматра решеном након провере да је ризик смањен на прихватљив ниво.  
Видљив доказ
-

# 02

ДРУГИ ДЕО

## Triage и реакција

Процена контекста одређује да ли отварамо инцидент и ко преузима реакцију.

Утицај

Власник

Хронологија

# Triage

провера контекста и утицаја

**01** Triage додаје сигналу контекст: коју имовину погађа и колики је могући утицај.

Питање: који улаз покреће ову одлуку?

**02** Озбиљност се одређује правилом, а не утиском особе која је на дужности.

Питање: која граница мора бити видљива?

**03** Одлука се образлаже, укључујући и разлог због ког је упозорење затворено.

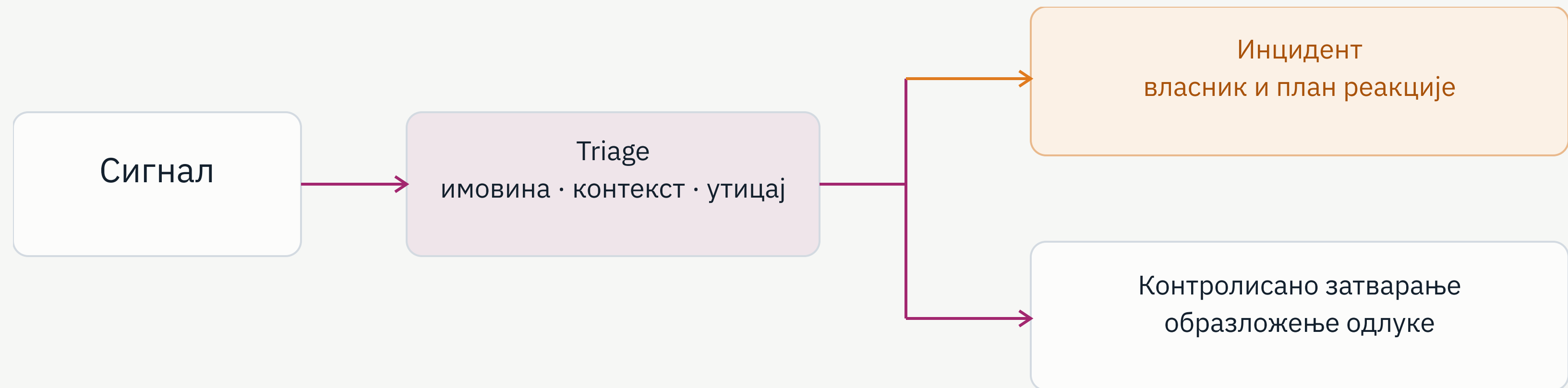
Питање: који доказ остаје после исхода?

## ПИТАЊЕ ЗА АНАЛИЗУ

Који податак о имовини мења озбиљност истог сигнала?

# Одлука после triage процене

Истоветан сигнал може имати различит приоритет у различитом контексту.



## Тумачење

Оба исхода чувају образложење. Процена користи договорене критеријуме и податке о имовини.

# Инцидент

координисана реакција

**01** Инцидент настаје из сигнала који је прошао triage и има власника реакције.

Питање: који улаз покреће ову одлуку?

**02** Поновљени сигнал се придружује постојећем инциденту уместо да отвара нови.

Питање: која граница мора бити видљива?

**03** Временска линија инцидента чува сигнале, одлуке и предузете радње.

Питање: који доказ остаје после исхода?

## ПИТАЊЕ ЗА АНАЛИЗУ

Ко у вашој целини преузима инцидент и по ком запису се види шта је урађено?

# Случај: више неуспелих пријава

Случај повезује опште правило са конкретним контекстом, серверском провером и очекиваним исходом.

## СЦЕНАРИО

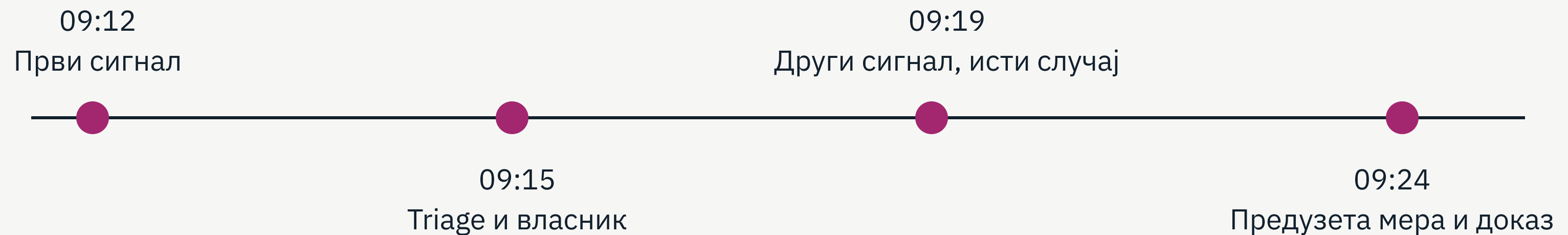
### Пример: више неуспелих пријава

Низ неуспелих пријава може значити погрешно запамћену лозинку, проблем интеграције или покушај злоупотребе. Сам број неуспеха зато није довољан за закључак. Triage додаје контекст: да ли су покушаји дошли са истог извора, да ли се односе на осетљиве налоге и да ли се образац наставља након упозорења.

- 01 Детекција треба да опише образац који је вредан пажње, а не да сваку грешку прогласи инцидентом.
- 02 Triage чува одлуку и образложење, укључујући разлог због ког је упозорење затворено.
- 03 Затварање рањивости тражи доказ да је изложеност уклоњена или прихваћена уз видљив преостали ризик.

# Временска линија инцидента

Илустративан ток једног случаја, са одлукама које се могу реконструисати.



## Тумачење

Поновљени сигнал допуњује постојећи случај. Запис повезује време, актера, одлуку и проверљив исход.

# 03

ТРЕЋИ ДЕО

## Рањивости

Налаз добија приоритет тек када знамо компоненту, изложеност и последицу.

Имовина

Приоритет

Корекција

Провера

# Ток управљања рањивошћу

Процес приказује улазе, место одлуке и доказ који остаје после исхода.

## КОНТЕКСТ

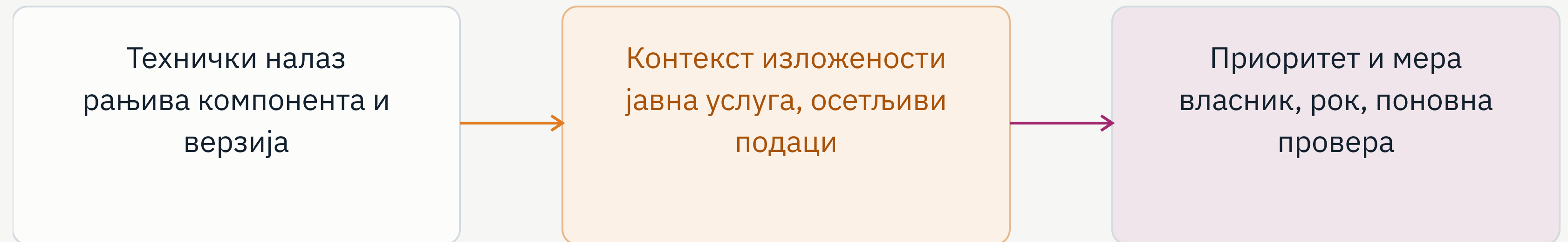
### Ток управљања рањивошћу

Налаз постаје користан тек када се повеже са стварном имовином и њеном изложеношћу. Исти технички проблем нема исти приоритет на изолованом развојном рачунару и на јавно доступној услузи која обрађује осетљиве податке.

- 01 Потврдити да се налаз односи на стварну компоненту и активну верзију.
- 02 Проценити утицај у контексту доступности, података и граница поверења.
- 03 Одредити корекцију, компензациону контролу или образложено прихватање ризика.
- 04 Затворити налаз тек када постоји доказ да је изложеност проверено смањена.

# Приоритет рањивости

Техничка озбиљност се тумачи за стварну имовину и њено окружење.



## Тумачење

Исти налаз не захтева исту реакцију у сваком систему. Затварање чува доказ смањене изложености и познат преостали ризик.

# Запис о сигналу и инциденту

JSON · илустративни пример

```
1  {
2    "signal": "login_failure_spike",
3    "asset": "admin-portal",
4    "severity": "high",
5    "owner": "security-on-call",
6    "status": "investigating",
7    "correlationId": "inc-2026-041"
8  }
```

## Повезан ревизиони траг

Актер, радња, циљ, исход и разлог

Временска ознака и correlation ID повезују траг са остатком тока.

## НЕ ПРИПАДА У ДОКАЗ

Лозинка, token, тајна и сувишан садржај

Траг не сме да постане нови извор цурења или збирка непотребних података.

# 04

ЧЕТВРТИ ДЕО

## Учење и провера

Постинцидентни преглед претвара искуство у акцију, тест и следећу проверу.

Чињенице

Власник акције

Тест

Примена

# Учење

корекција и превенција

**01** Постинцидентна анализа одваја чињенице од претпоставки насталих под притиском.

Питање: који улаз покреће ову одлуку?

**02** Корективна акција има власника и проверљив завршетак.

Питање: која граница мора бити видљива?

**03** Сценарио инцидента постаје тест, да се исто знање не изгуби.

Питање: који доказ остаје после исхода?

## ПИТАЊЕ ЗА АНАЛИЗУ

Који тест бисте додали после инцидента да се исти пропуст не понови?

# Постинцидентна анализа

Анализа повезује узрок, реакцију, пропуст контроле и конкретну корективну меру.

## ОБРАЗЛОЖЕЊЕ

### Учење након догађаја

Добар пост-инцидент преглед није потрага за особом која је погрешила. Његов циљ је да пронађе где су недостајали сигнал, заштитна провера, јасна одговорност или припрема за опоравак. Резултат треба да мења систем или процес на начин који се може проверити.

- 01 Хронологија одваја чињенице од претпоставки насталих под притиском.
- 02 Акције након инцидента имају власника и проверљив завршетак.
- 03 Нови сценарио се додаје у тестове или оперативне вежбе, како се исто знање не би изгубило.

# Примена у развоју

Тим примењује тему кроз серверске провере, тестове и ревизионе записе током развоја.

## РАЗВОЈНИ КОНТЕКСТ

### Примена принципа у коду

Тим бира мали број сигнала који су разумљиви оператеру. За сваки описује нормално понашање, разлог активирања, одговорну особу и безбедан начин провере. Тако се детекција дизајнира као производна могућност, а не као споредни лог.

---

01 Дефинисана одлука и њена граница.

---

02 Серверска имплементација провере.

---

03 Позитиван и негативан доказ.

# Честе грешке у имплементацији

Грешке настају када контекст, место одлуке или доказ остану нејасни.

---

## 01 Упозорење без власника и правила за triage.

Нема јасног власника одлуке.

---

## 02 Аутоматско затварање без доказа о решавању узрока.

Не постоји негативан сценарио.

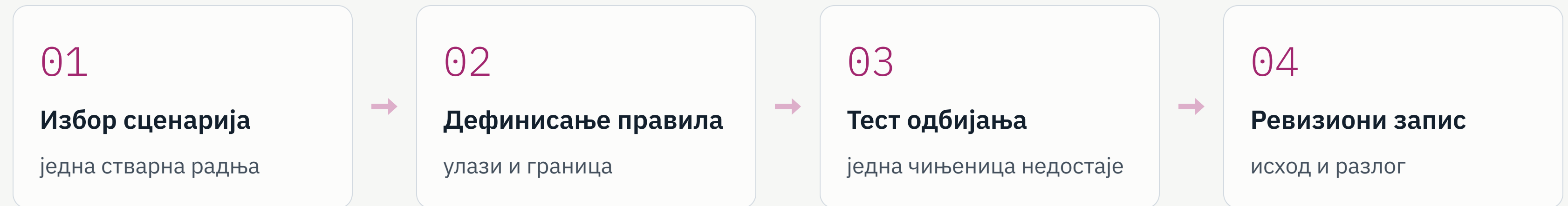
---

## 03 Скенирање зависности без одлуке како се налаз процењује и прати.

Доказ не показује стварни исход.

# Примена на пројекат

Анализа једног сценарија обухвата одлуку, имплементацију, тест одбијања и доказ.

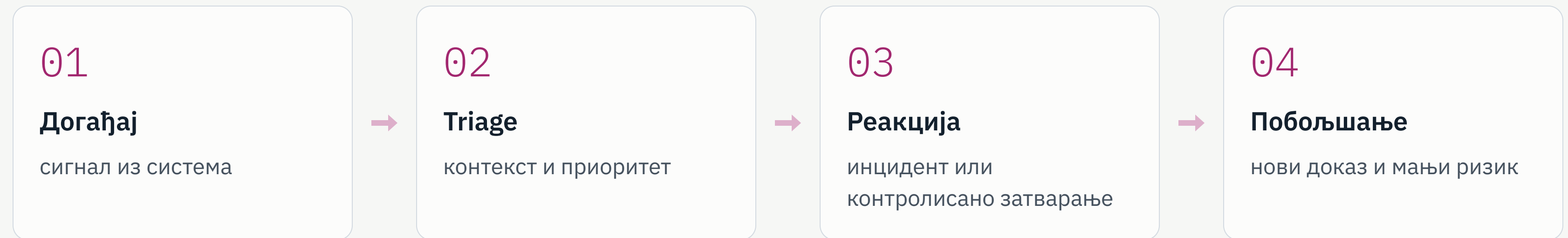


## ПРИМЕНА НА ПРОЈЕКАТ

Пројектна примена теме „Детекција, инцидент и рањивости“ обухвата једну серверску одлуку, тест одбијања и доказ који други члан тима може да понови.

# Модел одговора на безбедносни догађај

Значајни сигнали пролазе процену контекста и утицаја пре отварања инцидента. Исход анализе остаје доступан за наредне одлуке.

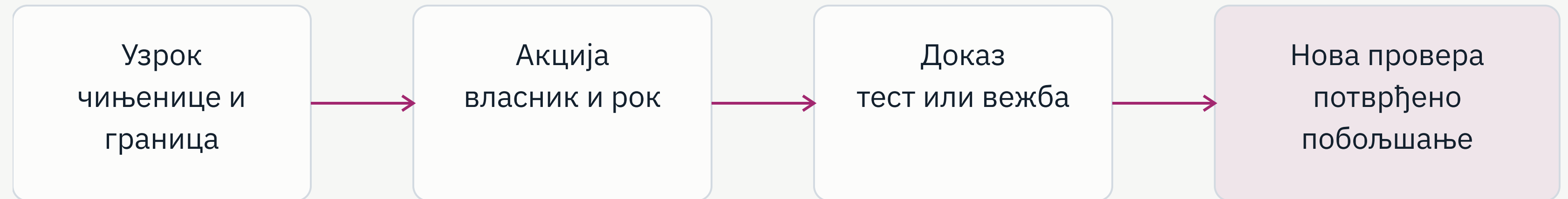


## ЕЛЕМЕНТИ АНАЛИЗЕ

Анализа сваког корака обухвата покретача, место одлуке и траг који остаје после исхода.

# Завршетак корективне акције

Затварање задатка и доказ побољшања су повезани кораци.



## Тумачење

Акција се проверава у сценарију који је изазвао проблем. Резултат улази у следећу процену ризика.

# Провера разумевања

Разумевање теме подразумева објашњење одлуке и доказа независно од конкретног технолошког оквира.

## Сигнал

уочено одступање

## Triage

провера контекста и утицаја

## Инцидент

координисана реакција

## Учење

корекција и превенција

**Који догађај би у вашем систему био користан сигнал, али не и довољан доказ инцидента? Који контекст недостаје?**

Пројектна примена: применити исти модел на једну реалну границу у сопственом пројекту.